

API endpoint reference

FDDT — Fraud Document Detection Tool API · version 0.1.0 · OpenAPI 3.1.0

47 operations across 38 paths and 69 data models. This reference is generated from the API definition itself (docs/api/openapi.json).

Conventions

- **Authentication:** endpoints marked `Bearer JWT` need the header `Authorization: Bearer <token>`. Obtain a token from `POST /auth/login` (email and password).
- **Roles** (ranked, each includes everything below it): `user` (submitter) < `reviewer_11` < `reviewer_12` < `admin`. "Reviewer/admin" means `reviewer_11` or above. On a case escalated to L2 (`assigned_tier` = `12`) only `reviewer_12` and `admin` may approve, reject or escalate; a `reviewer_11` gets 403 there but can still read the case. Role rules for each endpoint are stated in its description.
- **Errors:** every operation lists its documented error responses. 422 is a request-validation error.
- **Formats:** requests and responses are JSON (file uploads are `multipart/form-data`); identifiers are UUIDs; timestamps are ISO 8601.

Endpoint index

Method	Path	Summary
Health		
<code>GET</code>	<code>/health</code>	Liveness check
Authentication		
<code>POST</code>	<code>/auth/login</code>	Log in and obtain a JWT
<code>GET</code>	<code>/auth/me</code>	Get the current user
<code>GET</code>	<code>/auth/me/upload-limits</code>	Get my company's upload limits
<code>POST</code>	<code>/auth/me/password</code>	Change my password
Cases		
<code>POST</code>	<code>/cases</code>	Create a case
<code>GET</code>	<code>/cases</code>	List cases (the case queue)
<code>GET</code>	<code>/cases/{case_id}</code>	Get case detail
<code>GET</code>	<code>/cases/{case_id}/audit-log</code>	Get a case's activity timeline
Documents		
<code>POST</code>	<code>/cases/{case_id}/documents</code>	Upload a document to a case
<code>GET</code>	<code>/cases/{case_id}/documents/{document_id}/file-url</code>	Get a fresh signed URL for a document
Case actions (review decisions)		

Method	Path	Summary
POST	/cases/{case_id}/approve	Approve a case
POST	/cases/{case_id}/reject	Reject a case
POST	/cases/{case_id}/escalate	Escalate a case
Signature references & matches		
POST	/cases/{case_id}/documents/{document_id}/signature-references	Create a signature reference
GET	/cases/{case_id}/signature-references	List a case's signature references
GET	/cases/{case_id}/signature-matches	List a case's signature comparison results
Audit log		
GET	/audit-log	Search the audit log
GET	/audit-log/event-types	List audit event types
Case reports		
POST	/cases/{case_id}/reports	Generate a case report (PDF)
GET	/cases/{case_id}/reports	List a case's generated reports
Settings (admin)		
GET	/settings/issuers	List issuers
POST	/settings/issuers	Create an issuer
PATCH	/settings/issuers/{issuer_id}	Update or deactivate an issuer
GET	/settings/risk-rules	List current risk rules
POST	/settings/risk-rules	Create a risk rule
GET	/settings/risk-rule-options	Get the options for the Add-rule form
GET	/settings/risk-rules/{rule_id}/history	Get a risk rule's version history
PATCH	/settings/risk-rules/{rule_id}	Change a risk rule's weight, severity or active flag
GET	/settings/risk-thresholds	Get the risk tier thresholds
PUT	/settings/risk-thresholds	Set the risk tier thresholds
GET	/settings/users	List users
POST	/settings/users	Create a user
PATCH	/settings/users/{user_id}	Change a user's role, company or active flag
POST	/settings/users/{user_id}/reset-password	Reset user password (platform admin only)
Other		
POST	/bulk-uploads	Bulk upload: a zip of cases
GET	/bulk-uploads	List bulk uploads

Method	Path	Summary
GET	/bulk-uploads/{bulk_upload_id}	Bulk upload summary (live per-case status)
GET	/platform/companies	List companies
POST	/platform/companies	Create a company
PATCH	/platform/companies/{company_id}	Rename, suspend/reactivate, or change a company's upload limits
GET	/platform/risk-rule-templates	List the platform risk-rule template
POST	/platform/risk-rule-templates	Add a rule to the platform template
PATCH	/platform/risk-rule-templates/{rule_id}	Edit a platform template rule
GET	/platform/usage	Billing & usage by company
POST	/platform/usage/reconcile	Reconcile usage counters now
GET	/platform/queues	Processing queue monitor

Health

GET /health

Liveness check Public

Unauthenticated. Returns `{status: ok, environment}`; does not touch the database, Redis or Azure.

Responses

Status	Description	Body
200	Successful Response	map of string

Authentication

POST /auth/login

Log in and obtain a JWT Public

Exchanges email + password for a bearer token (HS256; lifetime from `JWT_ACCESS_TOKEN_EXPIRE_MINUTES`). The token carries `role`, `company_id` (null for a platform admin) and `is_platform_admin`. An unknown email, a wrong password, a deactivated account and a suspended company all return the same 401 so accounts cannot be enumerated.

Request body

[LoginRequest](#)

Responses

Status	Description	Body
200	Successful Response	TokenResponse
401	Incorrect email or password (or the account/company is inactive).	—
422	Validation Error	HTTPValidationError

GET `/auth/me`**Get the current user** Bearer JWT

Returns the authenticated user's profile, role and company. The role and company are re-read from the database on every request rather than trusted from the token, so a demotion, deactivation or company suspension takes effect immediately.

Responses

Status	Description	Body
200	Successful Response	CurrentUserResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—

GET `/auth/me/upload-limits`**Get my company's upload limits** Bearer JWT

The per-file and per-zip limits the caller's company is held to (set per company by a platform admin). Read fresh on every request, so upload screens always show the limit that will actually be enforced. Platform admins belong to no company: 404.

Responses

Status	Description	Body
200	Successful Response	UploadLimitsResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	Platform admins have no company and therefore no upload limits.	—

POST `/auth/me/password`**Change my password** Bearer JWT

Any signed-in user (every role) changes their own password by giving the current one. The new password (8-128 characters, different from the current one) is stored hashed and the change is recorded in the audit log (never the password). A forgotten password cannot be reset here: a platform admin resets it (`POST /settings/users/{id}/reset-password`). Tokens already issued stay valid until they expire.

Request body

[ChangePasswordRequest](#)

Responses

Status	Description	Body
204	Successful Response	—
400	The current password is wrong, or the new one equals it.	—
401	Missing, invalid or expired bearer token, or the user is inactive.	—
422	The new password is shorter than 8 or longer than 128 characters.	—

Cases

POST /cases

Create a case [Bearer JWT](#)

Opens an empty case (status `submitted`) owned by the caller, in the caller's company; any company role may create one (platform admins may not — 403). The case number is `CASE-` plus the first 8 hex characters of the case UUID. Attach documents afterwards with `POST /cases/{case_id}/documents`. Writes a `case_created` audit event.

Request body

[CaseCreateRequest](#)

Responses

Status	Description	Body
201	Successful Response	CaseResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Platform admins cannot create cases.	—
422	Validation Error	HTTPValidationError

GET /cases

List cases (the case queue) [Bearer JWT](#)

Only the caller's company. Reviewers see every case of their company; a `user` sees only the cases they submitted. A platform admin must pass `company_id` (one company at a time, audited) — there is no cross-company case list. For `reviewer_12` and platform admins, open cases escalated to L2 sort first; otherwise newest first. Optional filters: `status`, `case_type`, `assigned_tier`, and `actionable=true` (only cases the caller may act on — for a `reviewer_11` that excludes L2 cases). Each item carries `can_act`. For submitters `risk_tier` is null and `flag` is a neutral 'In review' marker, so scoring signals are never disclosed to them.

Parameters

Name	In	Type	Required	Description
<code>status</code>	query	CaseStatus (nullable)	no	
<code>case_type</code>	query	CaseType (nullable)	no	
<code>assigned_tier</code>	query	CaseTier (nullable)	no	
<code>actionable</code>	query	boolean	no	Only cases the caller may approve/reject/escalate.
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	array of CaseListItem
400	A platform admin did not pass <code>company_id</code> .	—
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	<code>company_id</code> names an unknown company (or, for a company user, not theirs).	—
422	Validation Error	HTTPValidationError

GET `/cases/{case_id}`

Get case detail Bearer JWT

Everything the case detail page needs in one call: documents (with signed download URLs, extracted fields and per-document check results), cross-document findings, forensic findings, the latest risk assessment, pipeline progress (`pipeline.complete` / `pipeline.pending`) and reviewer actions. A submitter does not receive the risk assessment and sees only approve/reject actions. A case of another company, or owned by someone else, is a 404, not a 403, so ids cannot be probed. A platform admin may read any company's case; each such access is written to that company's audit log.

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	

Responses

Status	Description	Body
200	Successful Response	CaseDetail
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	No such case (or, for a <code>user</code> , not one they submitted).	—
422	Validation Error	HTTPValidationError

GET `/cases/{case_id}/audit-log`

Get a case's activity timeline Bearer JWT

Chronological feed for the case detail page's activity timeline — System Specification section 3.5. Reads the same append-only `audit_log` rows every check task and case/document endpoint already writes; this adds no new events, just a way to read the ones that exist.

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	

Responses

Status	Description	Body
200	Successful Response	array of AuditLogEntrySchema

Status	Description	Body
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	No such case (or, for a <code>user</code> , not one they submitted).	—
422	Validation Error	<code>HTTPValidationError</code>

Documents

POST `/cases/{case_id}/documents`

Upload a document to a case `Bearer JWT`

One file per request (multipart field `file`). The original bytes are stored immutably in Blob Storage at `companies/{company_id}/cases/{case_id}/documents/{document_id}_{sha256}{ext}`, a `documents` row is written with the file's SHA-256, then the Celery pipeline is enqueued (extraction, metadata forensics, ELA/copy-move, duplicate detection, visual review, signature detection). The response returns immediately with `processing_status: pending`; poll GET `/cases/{case_id}` for progress. Before anything is stored or queued the file is validated: at most the company's per-file limit (`max_file_size_mb`, set by a platform admin; 10 MB by default), not empty, a PDF by its header bytes (not its name), a matching extension, and locally parseable (not corrupted, not password-protected). A rejection returns `detail: {code, message, ...}` with one of the codes `file_empty`, `file_too_large`, `unsupported_file_type`, `file_type_mismatch`, `file_corrupted`, `file_password_protected`. Each pipeline step is its own task on a shared, FIFO queue (see `app/tasks/celery_app.py`). A `user` may upload only to a case they submitted; reviewers to any case of their company; platform admins never (403).

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	

Request body

[Body_upload_document_cases__case_id_documents_post](#) (multipart/form-data)

Responses

Status	Description	Body
201	Successful Response	<code>DocumentResponse</code>
400	<code>file_empty</code> : the file is 0 bytes.	—
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Platform admins have read-only access.	—
404	No such case (or, for a <code>user</code> , not one they submitted).	—
413	<code>file_too_large</code> : over the size limit (<code>size_bytes</code> , <code>max_size_bytes</code>).	—

Status	Description	Body
415	<code>unsupported_file_type</code> (not a PDF by content; images are refused) or <code>file_type_mismatch</code> (extension names a different type than the content).	—
422	<code>file_corrupted</code> (cannot be parsed) or <code>file_password_protected</code> .	—
502	Blob Storage rejected the upload.	—

GET `/cases/{case_id}/documents/{document_id}/file-url`

Get a fresh signed URL for a document [Bearer JWT](#)

Mint a fresh signed URL for a document's original file — the URL handed back at upload time expires after a few minutes, which a reviewer working through the post-upload screen can easily outlast.

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	
<code>document_id</code>	path	string (uuid)	yes	

Responses

Status	Description	Body
200	Successful Response	DocumentFileUrlResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	No such document in this case (or, for a <code>user</code> , not their case).	—
422	Validation Error	HTTPValidationError
502	Blob Storage failed to sign the URL.	—

Case actions (review decisions)

POST `/cases/{case_id}/approve`

Approve a case [Bearer JWT](#)

Company reviewers only (platform admins: 403). Requires the automated pipeline to have finished and a risk assessment to exist (409 otherwise). Above `low` risk a written justification (`note` , at least 10 characters) is required (422). Approving an already-decided case is a 409. Writes a `case_actions` row and an audit event.

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	

Request body

[ApproveRequest](#)

Responses

Status	Description	Body
200	Successful Response	CaseDecisionResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a company reviewer role; a <code>reviewer_11</code> also gets 403 on a case escalated to L2.	—
404	No such case in your company.	—
409	Case already decided, checks still running, or an invalid state transition.	—
422	Case is above low risk and no justification of at least 10 characters was given.	—

POST `/cases/{case_id}/reject`

Reject a case [Bearer JWT](#)

Company reviewers only (platform admins: 403). A `reason` is required. Rejecting an already-decided case is a 409. Writes a `case_actions` row and an audit event.

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	

Request body

[RejectRequest](#)

Responses

Status	Description	Body
200	Successful Response	CaseDecisionResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a company reviewer role; a <code>reviewer_11</code> also gets 403 on a case escalated to L2.	—
404	No such case in your company.	—
409	Invalid state transition (e.g. already decided).	—
422	Validation Error	HTTPValidationError

POST `/cases/{case_id}/escalate`

Escalate a case [Bearer JWT](#)

Company reviewers only (platform admins: 403). Moves the case to the L2 tier (`assigned_tier = 12`); `status` is unchanged. A `reviewer_11` then keeps read access but can no longer act on it. There is no de-escalation — an L2 reviewer approves or rejects it. A `reason` is required. Escalating an already-escalated or decided case is a 409.

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	

Request body

[EscalateRequest](#)

Responses

Status	Description	Body
200	Successful Response	CaseDecisionResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a company reviewer role; a <code>reviewer_11</code> also gets 403 on a case escalated to L2.	—
404	No such case in your company.	—
409	Invalid state transition (e.g. already decided).	—
422	Validation Error	HTTPValidationError

Signature references & matches

POST `/cases/{case_id}/documents/{document_id}/signature-references`

Create a signature reference [Bearer JWT](#)

Create a signature reference from a reviewer-drawn bounding box.

Crops the signature region from the document's PDF, uploads it to Blob Storage, inserts the `signature_references` row, then immediately enqueues the in-case comparison Celery task for this reference.

`person_name` is required and must be typed by the reviewer — the system does not attempt to auto-extract it (System Specification §2.3).

Parameters

Name	In	Type	Required	Description
<code>case_id</code>	path	string (uuid)	yes	
<code>document_id</code>	path	string (uuid)	yes	

Request body

[SignatureReferenceCreate](#)

Responses

Status	Description	Body
201	Successful Response	SignatureReferenceResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Platform admins have read-only access.	—
404	No such case (or, for a <code>user</code> , not one they submitted), or the document is not in this case.	—
422	Validation Error	HTTPValidationError

GET /cases/{case_id}/signature-references

List a case's signature references Bearer JWT

All signature references created for this case. Used by the upload screen to list what references were set during this session.

Parameters

Name	In	Type	Required	Description
case_id	path	string (uuid)	yes	

Responses

Status	Description	Body
200	Successful Response	array of SignatureReferenceResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	No such case (or, for a <code>user</code> , not one they submitted).	—
422	Validation Error	HTTPValidationError

GET /cases/{case_id}/signature-matches

List a case's signature comparison results Bearer JWT

All in-case signature match results for this case, enriched with the reference person_name. Filtered to comparison_scope='in_case' only — library-scope matches are not generated yet (System Specification §2.3).

Parameters

Name	In	Type	Required	Description
case_id	path	string (uuid)	yes	

Responses

Status	Description	Body
200	Successful Response	array of SignatureMatchResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
404	No such case (or, for a <code>user</code> , not one they submitted).	—
422	Validation Error	HTTPValidationError

Audit log

GET /audit-log

Search the audit log Bearer JWT

Newest-first, paged read of the append-only `audit_log`, confined to the caller's company. Filters: `event_type`, `case_id` and free-text `q` (event type, case number, actor name/email). Company reviewers, and platform admins (`company_id` = one company's log, audited; omitted = the platform-level log).

Parameters

Name	In	Type	Required	Description
event_type	query	string (nullable)	no	
case_id	query	string (uuid) (nullable)	no	
q	query	string (nullable)	no	Matches event type, case number, actor name/email
company_id	query	string (uuid) (nullable)	no	Platform admins only.
limit	query	integer	no	
offset	query	integer	no	

Responses

Status	Description	Body
200	Successful Response	AuditPage
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a reviewer (L1 or L2) or platform admin role.	—
422	Validation Error	HTTPValidationError

GET /audit-log/event-types

List audit event types [Bearer JWT](#)

Distinct `event_type` values present in the caller's company's audit log (platform admins: the chosen company's, or the platform log), for the filter dropdown.

Parameters

Name	In	Type	Required	Description
company_id	query	string (uuid) (nullable)	no	Platform admins only.

Responses

Status	Description	Body
200	Successful Response	array of string
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a reviewer (L1 or L2) or platform admin role.	—
422	Validation Error	HTTPValidationError

Case reports

POST /cases/{case_id}/reports

Generate a case report (PDF) [Bearer JWT](#)

Company reviewers only. Renders the per-case forensic report PDF, stores it in Blob Storage under the company's `companies/{company_id}/cases/{case_id}/reports/` prefix, records a `case_reports` row (with the file's SHA-256) and returns it with a signed download URL. Every call creates a new report; earlier ones are kept.

Parameters

Name	In	Type	Required	Description
case_id	path	string (uuid)	yes	

Responses

Status	Description	Body
201	Successful Response	CaseReportResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a reviewer (L1 or L2) or <code>admin</code> role.	—
404	No such case.	—
422	Validation Error	HTTPValidationError
502	Blob Storage failed while saving or signing the report.	—

GET `/cases/{case_id}/reports`

List a case's generated reports [Bearer JWT](#)

Report history for the case, newest first.

Parameters

Name	In	Type	Required	Description
case_id	path	string (uuid)	yes	

Responses

Status	Description	Body
200	Successful Response	array of CaseReportResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires a reviewer (L1 or L2) or <code>admin</code> role.	—
404	No such case.	—
422	Validation Error	HTTPValidationError
502	Blob Storage failed while signing a download URL.	—

Settings (admin)

GET `/settings/issuers`

List issuers [Bearer JWT](#)

The company's issuer registry, ordered by name. Pass `include_inactive=false` to hide deactivated entries. Reviewer L2 (own company) or platform admin (`company_id`).

Parameters

Name	In	Type	Required	Description
<code>include_in_active</code>	query	boolean	no	
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	array of IssuerResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
422	Validation Error	HTTPValidationError

POST /settings/issuers

Create an issuer [Bearer JWT](#)

Adds a known vendor/school/etc. to the company's registry used by issuer verification. Names are unique (case-insensitively) among the company's active issuers.

Parameters

Name	In	Type	Required	Description
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Request body

[IssuerCreate](#)

Responses

Status	Description	Body
201	Successful Response	IssuerResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
409	An active issuer with this name already exists.	—
422	Validation Error	HTTPValidationError

PATCH /settings/issuers/{issuer_id}

Update or deactivate an issuer [Bearer JWT](#)

Partial update: only the fields sent are changed. Issuers are never deleted; set `is_active=false` to retire one. A request that changes nothing is a no-op. An issuer of another company is a 404.

Parameters

Name	In	Type	Required	Description
issuer_id	path	string (uuid)	yes	
company_id	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Request body

[IssuerUpdate](#)

Responses

Status	Description	Body
200	Successful Response	IssuerResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
404	No such issuer.	—
422	Validation Error	HTTPValidationError

GET [/settings/risk-rules](#)

List current risk rules [Bearer JWT](#)

The CURRENT version of every rule (active or not) of the company, by category.

Parameters

Name	In	Type	Required	Description
company_id	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	array of RiskRuleResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
422	Validation Error	HTTPValidationError

POST [/settings/risk-rules](#)

Create a risk rule [Bearer JWT](#)

A new rule at version 1, for this company only. It applies to the company's cases scored from now on; nothing already scored changes (assessments freeze the versions that produced them).

Parameters

Name	In	Type	Required	Description
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Request body

[RiskRuleCreate](#)

Responses

Status	Description	Body
201	Successful Response	RiskRuleResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
409	A rule with this <code>rule_id</code> already exists in the company.	—
422	The chosen match/parameters cannot be evaluated by the engine.	—

GET /settings/risk-rule-options

Get the options for the Add-rule form [Bearer JWT](#)

Everything the Add-rule form offers, so it never has to hardcode (or guess) what the checks can produce.

Responses

Status	Description	Body
200	Successful Response	object
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—

GET /settings/risk-rules/{rule_id}/history

Get a risk rule's version history [Bearer JWT](#)

Every version of one of the company's rules, newest first — the per-rule audit trail (who changed what, when). The same edits are also in `audit_log`.

Parameters

Name	In	Type	Required	Description
<code>rule_id</code>	path	string	yes	
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	array of RiskRuleResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
404	No such rule.	—
422	Validation Error	HTTPValidationError

PATCH [/settings/risk-rules/{rule_id}](#)

Change a risk rule's weight, severity or active flag [Bearer JWT](#)

Rules are versioned: an edit inserts a new immutable row (`version` + 1) and leaves the old one untouched, so every historical assessment stays truthful. Only `weight`, `severity` and `is_active` can be changed; at least one must differ. Only the company's own rule is affected.

Parameters

Name	In	Type	Required	Description
<code>rule_id</code>	path	string	yes	
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Request body

[RiskRuleUpdate](#)

Responses

Status	Description	Body
200	Successful Response	RiskRuleResponse
400	Nothing to change.	—
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
404	No such rule.	—
409	The rule was changed concurrently; reload and retry.	—
422	Validation Error	HTTPValidationError

GET [/settings/risk-thresholds](#)

Get the risk tier thresholds [Bearer JWT](#)

The company's scores at which a case becomes `medium` and `high` risk (defaults 30 and 60). The row is created on first read if it does not exist.

Parameters

Name	In	Type	Required	Description
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	RiskThresholdsResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
422	Validation Error	HTTPValidationError

PUT /settings/risk-thresholds

Set the risk tier thresholds [Bearer JWT](#)

Safe for history: each assessment embeds the thresholds it used.

Parameters

Name	In	Type	Required	Description
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Request body

[RiskThresholds](#)

Responses

Status	Description	Body
200	Successful Response	RiskThresholdsResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the Reviewer L2 role (or platform admin).	—
422	Validation Error	HTTPValidationError

GET /settings/users

List users [Bearer JWT](#)

Every account on the platform, ordered by company then email; filter with `company_id`. Platform admin only.

Parameters

Name	In	Type	Required	Description
<code>company_id</code>	query	string (uuid) (nullable)	no	

Responses

Status	Description	Body
200	Successful Response	array of UserAdminResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
422	Validation Error	HTTPValidationError

POST /settings/users

Create a user [Bearer JWT](#)

Creates an account and assigns it to a company + role. Company roles ([user](#) , [reviewer_11](#) , [reviewer_12](#)) need a [company_id](#) ; a [platform_admin](#) must have none. Platform admin only.

Request body

[UserCreate](#)

Responses

Status	Description	Body
201	Successful Response	UserAdminResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
404	No such company.	—
409	An account with that email already exists.	—
422	Company/role combination is invalid.	—

PATCH /settings/users/{user_id}

Change a user's role, company or active flag [Bearer JWT](#)

Partial update of [role](#) , [company_id](#) and/or [is_active](#) . A platform admin cannot change their own role or deactivate themselves (this also guarantees a platform admin always remains). Changing a user's company or role invalidates their existing tokens (they must sign in again). There is no self-service signup and no password-reset endpoint. Platform admin only.

Parameters

Name	In	Type	Required	Description
user_id	path	string (uuid)	yes	

Request body

[UserAdminUpdate](#)

Responses

Status	Description	Body
200	Successful Response	UserAdminResponse

Status	Description	Body
400	Attempted to change your own role or deactivate yourself.	—
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
404	No such user (or company).	—
422	Company/role combination is invalid.	—

POST /settings/users/{user_id}/reset-password

Reset user password (platform admin only) Bearer JWT

Resets the password for any user account. The new password is stored hashed. Only platform admins have access to this action. Action is logged in the audit trail.

Parameters

Name	In	Type	Required	Description
user_id	path	string (uuid)	yes	

Request body

[UserPasswordReset](#)

Responses

Status	Description	Body
200	Successful Response	UserAdminResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
404	No such user.	—
422	Validation Error	HTTPValidationError

Other

POST /bulk-uploads

Bulk upload: a zip of cases Bearer JWT

Request body: the zip file itself (`Content-Type: application/zip`), not multipart. Query: `case_type` (applied to every case) and `filename` (the zip's name, for display). The zip holds one top-level folder per case, each containing that case's documents directly. The response (202) returns once the zip is stored: it lists every case folder found, with structural failures already marked (subfolder in a case folder, empty folder, empty or file over the company's per-file limit). Documents are then extracted, validated with the same checks as a single upload, and each valid case is created and queued, one case at a time. Poll GET /bulk-uploads/{id}. Partial success: a bad file is rejected on its own and a case with no valid file fails on its own. Zip rejections return `detail: {code, message, ...}` with `zip_empty` , `zip_too_large` (over the company's zip limit, `max_zip_size_mb` , 300 MB by default, decided from Content-Length before the body is read), `not_a_zip` , `zip_corrupted` , `zip_too_many_entries` or `zip_no_case_folders` .

Parameters

Name	In	Type	Required	Description
<code>case_type</code>	query	CaseType	yes	Case type for every case in the zip.
<code>filename</code>	query	string	yes	The zip's file name.

Responses

Status	Description	Body
202	Successful Response	BulkUploadDetail
400	<code>zip_empty</code> .	—
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Platform admins have read-only access.	—
413	<code>zip_too_large</code> (<code>size_bytes</code> , <code>max_size_bytes</code>).	—
415	<code>not_a_zip</code> .	—
422	<code>zip_corrupted</code> , <code>zip_too_many_entries</code> , <code>zip_no_case_folders</code> .	—
502	Blob Storage rejected the upload.	—

GET /bulk-uploads

List bulk uploads [Bearer JWT](#)

Newest first. A `user` sees only their own; reviewers see their company's. Platform admins pass `company_id` (audited).

Parameters

Name	In	Type	Required	Description
<code>limit</code>	query	integer	no	
<code>company_id</code>	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	array of BulkUploadSummary
422	Validation Error	HTTPValidationError

GET /bulk-uploads/{bulk_upload_id}

Bulk upload summary (live per-case status) [Bearer JWT](#)

Every case folder of the zip with its outcome (created / failed and why, per file) and, for created cases, live progress (queued → processing → done / flagged). Poll until `settled`. Another user's upload (for a `user`) or another company's is a 404.

Parameters

Name	In	Type	Required	Description
bulk_upload_id	path	string (uuid)	yes	
company_id	query	string (uuid) (nullable)	no	Platform admins only (required for them): the company to act on. Company users are always confined to their own company.

Responses

Status	Description	Body
200	Successful Response	BulkUploadDetail
422	Validation Error	HTTPValidationError

GET /platform/companies

List companies [Bearer JWT](#)

Responses

Status	Description	Body
200	Successful Response	array of CompanyResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—

POST /platform/companies

Create a company [Bearer JWT](#)

Creates a client company and copies every active platform rule template into its own risk rules, plus default tier thresholds (its own independent copy, which its Reviewer L2s can then tune; later template edits don't affect it). The issuer registry starts empty. Users are added separately (Settings > Users).

Request body

[CompanyCreate](#)

Responses

Status	Description	Body
201	Successful Response	CompanyResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
409	A company with this name already exists.	—
422	Validation Error	HTTPValidationError

PATCH /platform/companies/{company_id}

Rename, suspend/reactivate, or change a company's upload limits Bearer JWT

`is_active=false` suspends the company: its users can no longer sign in, and existing tokens stop working on the next request. Data is kept. `max_file_size_mb` / `max_zip_size_mb` change the company's upload limits (any positive whole number of MB; no upper ceiling), effective on its next upload with no new sign-in. Every change is written to the platform audit log as `company_updated` with old → new values.

Parameters

Name	In	Type	Required	Description
<code>company_id</code>	path	string (uuid)	yes	

Request body

[CompanyUpdate](#)

Responses

Status	Description	Body
200	Successful Response	CompanyResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
404	No such company.	—
409	Name taken.	—
422	Validation Error	HTTPValidationError

GET /platform/risk-rule-templates

List the platform risk-rule template Bearer JWT

The default rule set copied into every NEW company's own risk rules at creation time. Editing it never changes companies that already exist.

Responses

Status	Description	Body
200	Successful Response	array of RuleTemplateResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—

POST /platform/risk-rule-templates

Add a rule to the platform template Bearer JWT

Same rule builder as a company's Add-rule form. Applies to companies created from now on.

Request body

[RiskRuleCreate](#)

Responses

Status	Description	Body
201	Successful Response	RuleTemplateResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
409	A template rule with this rule_id already exists.	—
422	Validation Error	HTTPValidationError

PATCH `/platform/risk-rule-templates/{rule_id}`

Edit a platform template rule [Bearer JWT](#)

Changes weight, severity, wording or active flag. Existing companies keep their own copies unchanged; only companies created afterwards start from the new values.

Parameters

Name	In	Type	Required	Description
rule_id	path	string	yes	

Request body

[RuleTemplateUpdate](#)

Responses

Status	Description	Body
200	Successful Response	RuleTemplateResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
404	No such template rule.	—
422	Validation Error	HTTPValidationError

GET `/platform/usage`

Billing & usage by company [Bearer JWT](#)

One row per company for the period: cases created, documents uploaded, files stored (documents + generated reports) and bytes stored during the period, plus each company's current all-time storage. Read from incrementally-maintained daily counters (company_usage_stats), not live scans of the case tables; a nightly job reconciles them against the source data. Periods use UTC days.

Parameters

Name	In	Type	Required	Description
period	query	string: "this_month", "last_month", "last_30_days", "this_year", "all_time", "custom"	no	

Name	In	Type	Required	Description
start	query	string (date) (nullable)	no	custom period only
end	query	string (date) (nullable)	no	custom period only

Responses

Status	Description	Body
200	Successful Response	UsageResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—
422	Validation Error	HTTPValidationError

POST /platform/usage/reconcile

Reconcile usage counters now [Bearer JWT](#)

Recomputes every company's daily counters from the cases/documents/reports tables and corrects any drift (the same job runs nightly). Returns what was corrected; a correction is also written to the platform audit log.

Responses

Status	Description	Body
200	Successful Response	ReconcileResponse
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—

GET /platform/queues

Processing queue monitor [Bearer JWT](#)

Per queue (extraction / vision / forensics): tasks waiting and running, age of the oldest waiting task, average / p95 / max wait over the window, average run time, the rate limit in force and the limiter's counters (calls throttled, Azure 429s), and the worker processes consuming it. Wait times are measured from enqueue to start.

Parameters

Name	In	Type	Required	Description
window_minutes	query	integer	no	

Responses

Status	Description	Body
200	Successful Response	object
401	Missing, invalid or expired bearer token, or the user is inactive.	—
403	Requires the platform admin role.	—

Status	Description	Body
422	Validation Error	HTTPValidationError

Data models

ApproveRequest

Field	Type	Required	Description
<code>note</code>	string (nullable)	no	Justification. Optional for low-risk cases; at least 10 characters (after trimming) is required to approve a medium- or high-risk case.

AuditEventResponse

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>created_at</code>	string (date-time)	yes	
<code>event_type</code>	string	yes	
<code>actor_name</code>	string (nullable)	yes	
<code>actor_email</code>	string (nullable)	yes	
<code>case_id</code>	string (uuid) (nullable)	yes	
<code>case_number</code>	string (nullable)	yes	
<code>document_id</code>	string (uuid) (nullable)	yes	
<code>document_filename</code>	string (nullable)	yes	
<code>event_data</code>	object (nullable)	yes	

AuditLogEntrySchema

One `audit_log` row scoped to a case — System Specification section 3.5's "review history/timeline ... built from the same audit log." Every `event_type` here is a real one already written by `app/services/audit_service.py`'s call sites (case creation, uploads, and each Celery check task) — nothing here is synthesized for display.

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>event_type</code>	string	yes	
<code>actor_name</code>	string (nullable)	yes	
<code>document_id</code>	string (uuid) (nullable)	yes	
<code>event_data</code>	object (nullable)	yes	
<code>created_at</code>	string (date-time)	yes	

AuditPage

Field	Type	Required	Description
items	array of AuditEventResponse	yes	
total	integer	yes	

Body_upload_document_cases__case_id__documents_post

Field	Type	Required	Description
file	string (binary)	yes	

BoundingBoxSchema

Normalized bounding box — page-fraction (0-1) coordinates, same convention as every other bounding box in this codebase (ELA, copy-move, visual inconsistency). `page` is 1-based.

Field	Type	Required	Description
page	integer	yes	
x	number	yes	
y	number	yes	
width	number	yes	
height	number	yes	

BulkUploadCaseSchema

Field	Type	Required	Description
index	integer	yes	
folder	string	yes	
status	string: "pending", "created", "failed"	yes	
error_code	string (nullable)	no	
error_message	string (nullable)	no	
case_id	string (uuid) (nullable)	no	
case_number	string (nullable)	no	
files	array of BulkUploadFileSchema	yes	
live_status	string: "validating", "failed", "queued", "processing", "done", "flagged"	yes	
case_status	CaseStatus (nullable)	no	
documents_total	integer	no	
documents_finished	integer	no	
flag	CaseFlagSchema (nullable)	no	

BulkUploadDetail

Field	Type	Required	Description
id	string (uuid)	yes	
original_filename	string	yes	
case_type	CaseType	yes	
status	BulkUploadStatus	yes	
error_code	string (nullable)	yes	
error_message	string (nullable)	yes	
zip_size_bytes	integer	yes	
case_folder_count	integer (nullable)	yes	
cases_created	integer	yes	
cases_failed	integer	yes	
documents_accepted	integer	yes	
documents_rejected	integer	yes	
uploaded_by	UserSummary (nullable)	yes	
created_at	string (date-time)	yes	
started_at	string (date-time) (nullable)	yes	
finished_at	string (date-time) (nullable)	yes	
wrapper_folder	string (nullable)	no	
ignored_entries	array of string	no	
ignored_entry_count	integer	no	
warnings	array of string	no	
progress	BulkUploadProgress	yes	
settled	boolean	yes	
cases	array of BulkUploadCaseSchema	yes	

BulkUploadFileSchema

Field	Type	Required	Description
name	string	yes	
status	string: "pending", "accepted", "rejected", "skipped"	yes	
code	string (nullable)	no	
message	string (nullable)	no	
size_bytes	integer (nullable)	no	
document_id	string (uuid) (nullable)	no	

BulkUploadProgress

Field	Type	Required	Description
validating	integer	no	
failed	integer	no	
queued	integer	no	
processing	integer	no	
done	integer	no	
flagged	integer	no	

BulkUploadStatus

Allowed values: "queued", "ingesting", "complete", "failed"

BulkUploadSummary

Field	Type	Required	Description
id	string (uuid)	yes	
original_filename	string	yes	
case_type	CaseType	yes	
status	BulkUploadStatus	yes	
error_code	string (nullable)	yes	
error_message	string (nullable)	yes	
zip_size_bytes	integer	yes	
case_folder_count	integer (nullable)	yes	
cases_created	integer	yes	
cases_failed	integer	yes	
documents_accepted	integer	yes	
documents_rejected	integer	yes	
uploaded_by	UserSummary (nullable)	yes	
created_at	string (date-time)	yes	
started_at	string (date-time) (nullable)	yes	
finished_at	string (date-time) (nullable)	yes	

CaseActionSchema

A reviewer decision/note on the case (approve/reject/escalate).

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>action_type</code>	string	yes	
<code>actor_name</code>	string (nullable)	yes	
<code>actor_role</code>	string (nullable)	no	Display label of the actor's role when they acted, e.g. 'Reviewer L1'.
<code>notes</code>	string (nullable)	yes	
<code>created_at</code>	string (date-time)	yes	

CaseCreateRequest

Field	Type	Required	Description
<code>case_type</code>	CaseType	yes	Case-level category chosen at submission. Independent of each document's own <code>document_type</code> , which the classification step fills in later.

CaseDecisionResponse

Field	Type	Required	Description
<code>case_id</code>	string (uuid)	yes	
<code>status</code>	CaseStatus	yes	
<code>assigned_tier</code>	CaseTier	yes	
<code>action</code>	CaseActionSchema	yes	

CaseDetail

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>case_number</code>	string	yes	
<code>case_type</code>	CaseType	yes	
<code>status</code>	CaseStatus	yes	
<code>assigned_tier</code>	CaseTier	yes	
<code>risk_tier</code>	RiskTier (nullable)	yes	
<code>submitted_by</code>	UserSummary (nullable)	no	
<code>created_at</code>	string (date-time)	yes	
<code>document_count</code>	integer	yes	
<code>flag</code>	CaseFlagSchema	yes	
<code>can_act</code>	boolean	yes	Whether the caller may approve/reject/escalate this case given its tier. False for submitters, and for a <code>reviewer_11</code> on an L2-assigned case (read-only). Does not reflect status — a decided case is still <code>can_act</code> but every action is a 409.
<code>documents</code>	array of CaseDocumentSummary	yes	
<code>cross_document_findings</code>	array of CrossDocumentFindingSummary	yes	
<code>forensic_findings</code>	array of ForensicFindingSummary	yes	
<code>assessment</code>	RiskAssessmentSchema (nullable)	yes	
<code>pipeline</code>	PipelineStatusSchema	yes	
<code>actions</code>	array of CaseActionSchema	yes	

CaseDocumentSummary

A document as shown on the case-detail page. `file_url` here is a short-lived signed URL (see `StorageService.get_download_url`) — the storage container is private, so the durable URL alone isn't browser-fetchable.

`document_type` and `extracted_fields` are filled in by the OCR + classification + extraction Celery pipeline (`app/tasks/document_processing.py`) — both stay null until `processing_status` reaches "complete".

`extracted_fields` shape: {"document_type_confidence": float, "core_fields": {name: {value, confidence, uncertain}}, "additional_fields": [{field_name, value, confidence, uncertain}]}.

`checks` is filled in afterward by `app/tasks/document_checks.py` (`field_validation`, `issuer_verification`, and later the forensic checks) — empty until those complete.

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>original_filename</code>	string	yes	
<code>document_type</code>	string (nullable)	yes	
<code>processing_status</code>	string	yes	
<code>extracted_fields</code>	object (nullable)	yes	
<code>processing_error</code>	string (nullable)	yes	
<code>content_type</code>	string (nullable)	yes	
<code>file_size_bytes</code>	integer (nullable)	yes	
<code>file_hash</code>	string	yes	
<code>file_url</code>	string	yes	
<code>uploaded_at</code>	string (date-time)	yes	
<code>checks</code>	array of DocumentCheckSummary	yes	

CaseFlagSchema

Wire shape of `app/services/case_flag_service.py`'s `CaseFlag`: the case's real risk tier (low/medium/high), or "pending" until scored.

Field	Type	Required	Description
<code>flag</code>	string: "low", "medium", "high", "pending"	yes	
<code>label</code>	string	yes	
<code>description</code>	string	yes	
<code>score</code>	integer (nullable)	no	

CaseListItem

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>case_number</code>	string	yes	
<code>case_type</code>	CaseType	yes	
<code>statuses</code>	CaseStatus	yes	
<code>assigned_tier</code>	CaseTier	yes	
<code>risk_tier</code>	RiskTier (nullable)	yes	
<code>submitted_by</code>	UserSummary (nullable)	no	
<code>created_at</code>	string (date-time)	yes	
<code>document_count</code>	integer	yes	
<code>flag</code>	CaseFlagSchema	yes	
<code>can_act</code>	boolean	yes	Whether the caller may approve/reject/escalate this case given its tier. False for submitters, and for a <code>reviewer_11</code> on an L2-assigned case (read-only). Does not reflect status — a decided case is still <code>can_act</code> but every action is a 409.

CaseReportResponse

One generated report. `download_url` is a short-lived signed URL (the container is private — see `app/services/storage_service.py`), so it is minted fresh on every response rather than stored.

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>case_id</code>	string (uuid)	yes	
<code>generated_by_name</code>	string (nullable)	yes	
<code>generated_at</code>	string (date-time)	yes	
<code>file_size_bytes</code>	integer	yes	
<code>page_count</code>	integer	yes	
<code>report_sha256</code>	string	yes	
<code>risk_tier</code>	string (nullable)	yes	
<code>risk_score</code>	integer (nullable)	yes	
<code>download_url</code>	string	yes	

CaseResponse

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>case_number</code>	string	yes	
<code>case_type</code>	CaseType	yes	
<code>status</code>	CaseStatus	yes	
<code>assigned_tier</code>	CaseTier	yes	
<code>risk_tier</code>	RiskTier (nullable)	yes	
<code>submitted_by_user_id</code>	string (uuid)	yes	
<code>created_at</code>	string (date-time)	yes	

CaseStatus

Allowed values: `"submitted"`, `"under_automated_review"`, `"pending_manual_review"`, `"auto_approved"`, `"escalated"`, `"under_investigation"`, `"approved"`, `"rejected"`, `"closed"`

CaseTier

Which reviewer tier owns the case — orthogonal to `status`. Every case starts at `11`; escalating it moves it to `12` (one-directional, there is no de-escalation). On an `12` case a `reviewer_11` keeps read access but every action endpoint returns 403; `reviewer_12` and `admin` can act on cases of either tier.

Allowed values: `"11"`, `"12"`

CaseType

Case-level category, selected at submission time (System Specification section 3.6's document-type coverage list). This is separate from a document's own `document_type`, which is filled in later by the classification step — a case can hold documents of more than one type (e.g. an invoice plus its approval voucher).

Allowed values: `"school_document"`, `"vendor_invoice"`, `"commercial_invoice"`, `"procurement_documentation"`, `"quotation"`, `"travel_reimbursement"`, `"other"`

ChangePasswordRequest

Change your own password. The current password is required; a forgotten password is reset by a platform admin instead (there is no self-service reset).

Field	Type	Required	Description
<code>current_password</code>	string	yes	Your current password.
<code>new_password</code>	string	yes	New password (8-128 chars); stored hashed.

CompanyCreate

Field	Type	Required	Description
<code>name</code>	string	yes	
<code>max_file_size_mb</code>	integer (nullable)	no	Max document size in MB (per company).
<code>max_zip_size_mb</code>	integer (nullable)	no	Max bulk-upload zip size in MB (per company).

CompanyResponse

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>name</code>	string	yes	
<code>is_active</code>	boolean	yes	
<code>created_at</code>	string (date-time)	yes	
<code>user_count</code>	integer	yes	
<code>max_file_size_mb</code>	integer	yes	Largest document this company may upload, in MB.
<code>max_zip_size_mb</code>	integer	yes	Largest bulk-upload zip this company may upload, in MB.

CompanyUpdate

Field	Type	Required	Description
<code>name</code>	string (nullable)	no	
<code>is_active</code>	boolean (nullable)	no	
<code>max_file_size_mb</code>	integer (nullable)	no	Max document size in MB (per company).
<code>max_zip_size_mb</code>	integer (nullable)	no	Max bulk-upload zip size in MB (per company).

CompanyUsageRow

Field	Type	Required	Description
company_id	string (uuid)	yes	
company_name	string	yes	
is_active	boolean	yes	
cases_created	integer	yes	
documents_uploaded	integer	yes	
files_stored	integer	yes	
storage_bytes	integer	yes	
total_storage_bytes	integer	yes	
total_files_stored	integer	yes	

CrossDocumentFindingSummary

One `cross_document_findings` row (System Specification section 3.1, "Cross-document validation & reconciliation") — a shared field (amount/date/issuer) that disagreed between two of this case's documents. Case-level, not per-document — see `app/services/cross_document_service.py` and `app/tasks/document_checks.py`.

Field	Type	Required	Description
id	string (uuid)	yes	
field_name	string	yes	
finding_type	string	yes	
severity	string	yes	
description	string	yes	
document_ids	array of string (nullable)	yes	
created_at	string (date-time)	yes	
regions	array of object	no	

CurrentUserResponse

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>email</code>	string (email)	yes	
<code>full_name</code>	string (nullable)	yes	Display name, if one was set.
<code>role</code>	UserRole	yes	<code>user</code> (submitter), <code>reviewer_11</code> , <code>reviewer_12</code> (company roles) or <code>platform_admin</code> .
<code>role_label</code>	string	yes	Display label, e.g. "Reviewer L2".
<code>is_active</code>	boolean	yes	Deactivated accounts are rejected on every request.
<code>is_platform_admin</code>	boolean	yes	True for platform admins, who belong to no company.
<code>company_id</code>	string (uuid) (nullable)	yes	The user's company; null for a platform admin.
<code>company_name</code>	string (nullable)	yes	Display name of the user's company.

DocumentCheckSummary

One `document_checks` row (System Specification sections 2.2/3.1/3.2 — `field_validation`, `issuer_verification`, and later the forensic checks). `result` holds whatever shape that `check_type` produces — see the individual check services (e.g. `app/services/field_validation_service.py`) for what's inside — the frontend's Checks panel renders it generically rather than assuming a fixed schema per `check_type`.

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>check_type</code>	string	yes	
<code>status</code>	string	yes	
<code>result</code>	object (nullable)	yes	
<code>error_message</code>	string (nullable)	yes	
<code>created_at</code>	string (date-time)	yes	
<code>summary</code>	object (nullable)	no	

DocumentFileUrlResponse

A fresh short-lived signed URL for one document's original file.

Field	Type	Required	Description
<code>file_url</code>	string	yes	

DocumentResponse

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>case_id</code>	string (uuid)	yes	
<code>original_filename</code>	string	yes	
<code>content_type</code>	string (nullable)	yes	
<code>file_size_bytes</code>	integer (nullable)	yes	
<code>file_hash</code>	string	yes	
<code>file_url</code>	string	yes	
<code>uploaded_at</code>	string (date-time)	yes	
<code>processing_status</code>	string	yes	

EscalateRequest

Field	Type	Required	Description
<code>reason</code>	string	yes	Why the case needs an L2 reviewer. Required and must not be blank.

ForensicFindingSummary

One medium/high-severity finding from a flagged `metadata_forensics/` `error_level_analysis/copy_move_detection` check — the per-document counterpart to `CrossDocumentFindingSummary`, both shown together in the case detail "Explainable findings" panel. See `app/services/case_flag_service.py`'s `get_forensic_findings` for what feeds this and why it's a temporary stand-in for the real risk-scoring engine.

Field	Type	Required	Description
<code>document_id</code>	string (uuid)	yes	
<code>document_filename</code>	string	yes	
<code>check_type</code>	string	yes	
<code>check_type_label</code>	string	yes	
<code>finding</code>	string	yes	
<code>severity</code>	string	yes	
<code>description</code>	string	yes	

HTTPValidationError

Field	Type	Required	Description
<code>detail</code>	array of ValidationError	no	

IssuerCreate

Field	Type	Required	Description
name	string	yes	English/Latin issuer name.
name_arabic	string (nullable)	no	Arabic-script name, matched separately during issuer verification.
tax_id	string (nullable)	no	Tax/VAT registration number, if known.
type	IssuerType	no	Kind of issuer (vendor, school, ...).

IssuerResponse

Field	Type	Required	Description
id	string (uuid)	yes	
name	string	yes	
name_arabic	string (nullable)	yes	
tax_id	string (nullable)	yes	
type	IssuerType	yes	
is_active	boolean	yes	
created_at	string (date-time)	yes	
updated_at	string (date-time)	yes	

IssuerType

Allowed values: "vendor", "school", "government", "other"

IssuerUpdate

Field	Type	Required	Description
name	string (nullable)	no	
name_arabic	string (nullable)	no	
tax_id	string (nullable)	no	
type	IssuerType (nullable)	no	
is_active	boolean (nullable)	no	

LoginRequest

Field	Type	Required	Description
email	string (email)	yes	Account email (matched exactly as stored).
password	string	yes	Account password.

PipelineStatusSchema

Whether every automated check has finished. `pending` names what is still outstanding — shown to the reviewer when Approve is disabled.

Field	Type	Required	Description
<code>complete</code>	boolean	yes	
<code>pending</code>	array of string	yes	

ReconcileResponse

Field	Type	Required	Description
<code>rows_checked</code>	integer	yes	
<code>rows_corrected</code>	integer	yes	
<code>drift</code>	array of object	yes	

RejectRequest

Field	Type	Required	Description
<code>reason</code>	string	yes	Why the case is rejected. Required and must not be blank.

RiskAssessmentSchema

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>score</code>	integer	yes	
<code>raw_score</code>	number	yes	
<code>tier</code>	RiskTier	yes	
<code>computed_at</code>	string (date-time)	yes	
<code>triggered_reasons</code>	array of RiskReasonSchema	yes	
<code>thresholds</code>	map of integer	yes	
<code>group_caps</code>	map of map of number	no	

RiskReasonSchema

One fired rule, as frozen at scoring time (rendered text, weight and rule version) — see [app/models/case_risk_assessment.py](#).

Field	Type	Required	Description
<code>rule_id</code>	string	yes	
<code>rule_version</code>	integer	yes	
<code>category</code>	string	yes	
<code>check_type</code>	string	yes	
<code>severity</code>	string	yes	
<code>weight</code>	number	yes	
<code>reason</code>	string	yes	
<code>document_id</code>	string (uuid) (nullable)	yes	
<code>document_filename</code>	string (nullable)	yes	
<code>title</code>	string	no	
<code>short</code>	string	no	

RiskRuleCreate

A brand-new rule (version 1). The admin picks a rule TYPE and its parameters from the catalog (GET /settings/risk-rule-options); the API builds and validates the engine `condition` from them — nobody writes JSON, and a choice the engine can't evaluate is rejected.

Field	Type	Required	Description
<code>rule_id</code>	string	yes	Stable key, lower-case with a dot: e.g. custom.editing_tool_seen
<code>category</code>	string: "forensics", "consistency", "verification", "duplication"	yes	
<code>match</code>	string: "finding", "check_result", "sub_check", "cross_document", "signature_match"	yes	
<code>check_type</code>	string (nullable)	no	
<code>finding</code>	string (nullable)	no	
<code>severity_in</code>	array of string: "low", "medium", "high" (nullable)	no	
<code>sub_check</code>	string (nullable)	no	
<code>field_name</code>	string (nullable)	no	
<code>signature_result</code>	string (nullable)	no	
<code>weight</code>	number	yes	
<code>severity</code>	string: "low", "medium", "high"	yes	
<code>reason_template</code>	string	yes	
<code>is_active</code>	boolean	no	
<code>change_note</code>	string (nullable)	no	

RiskRuleResponse

One (current or historical) version of a rule.

Field	Type	Required	Description
<code>id</code>	string (uuid)	yes	
<code>rule_id</code>	string	yes	
<code>category</code>	string	yes	
<code>check_type</code>	string	yes	
<code>weight</code>	number	yes	
<code>severity</code>	string	yes	
<code>reason_template</code>	string	yes	
<code>is_active</code>	boolean	yes	
<code>version</code>	integer	yes	
<code>effective_from</code>	string (date-time)	yes	
<code>updated_by_name</code>	string (nullable)	yes	
<code>change_note</code>	string (nullable)	yes	

RiskRuleUpdate

An edit. Never mutates the existing row: the API inserts version+1.

Field	Type	Required	Description
<code>weight</code>	number (nullable)	no	Points added to the case score when the rule fires.
<code>severity</code>	string: "low", "medium", "high" (nullable)	no	Severity shown beside the rule's reason.
<code>is_active</code>	boolean (nullable)	no	Inactive rules are evaluated but never fire.
<code>change_note</code>	string (nullable)	no	Why the change was made.

RiskThresholds

Field	Type	Required	Description
<code>medium_threshold</code>	integer	yes	Score at or above which a case is <code>medium</code> risk.
<code>high_threshold</code>	integer	yes	Score at or above which a case is <code>high</code> risk. Must exceed the medium threshold.
<code>metadata_score_cap</code>	integer (nullable)	no	Most points the metadata rules (<code>metadata.*</code>) may add together — one edit leaves several metadata traces. 100 = no cap. Omitted: unchanged.

RiskThresholdsResponse

Field	Type	Required	Description
medium_threshold	integer	yes	Score at or above which a case is <code>medium</code> risk.
high_threshold	integer	yes	Score at or above which a case is <code>high</code> risk. Must exceed the medium threshold.
metadata_score_cap	integer	yes	
updated_at	string (date-time)	yes	
updated_by_name	string (nullable)	yes	

RiskTier

Allowed values: `"low"`, `"medium"`, `"high"`

RuleTemplateResponse

Field	Type	Required	Description
id	string (uuid)	yes	
rule_id	string	yes	
category	string	yes	
check_type	string	yes	
condition	object	yes	
weight	number	yes	
severity	string	yes	
reason_template	string	yes	
is_active	boolean	yes	
updated_at	string (date-time)	yes	

RuleTemplateUpdate

Field	Type	Required	Description
weight	number (nullable)	no	
severity	string: <code>"low"</code> , <code>"medium"</code> , <code>"high"</code> (nullable)	no	
reason_template	string (nullable)	no	
is_active	boolean (nullable)	no	

SignatureMatchResponse

One signature_matches row returned by the API, enriched with the reference's person_name so the frontend can show "compared against [name]" without a separate reference lookup.

Field	Type	Required	Description
id	string (uuid)	yes	
document_id	string (uuid)	yes	
case_id	string (uuid)	yes	
signature_reference_id	string (uuid)	yes	
reference_person_name	string	yes	
comparison_scope	string	yes	
result	string	yes	
result_label	string	yes	
reasoning	string (nullable)	yes	
compared_at	string (date-time)	yes	

SignatureReferenceCreate

Request body for POST /cases/{case_id}/documents/{document_id}/signature-references.

person_name is required and must be provided by the reviewer — the system never attempts to auto-extract or pre-fill it (System Specification §2.3).

Field	Type	Required	Description
person_name	string	yes	Name of the person whose signature this is, typed by the reviewer. Required — the system does not attempt to auto-extract this field.
bounding_box	BoundingBoxSchema	yes	
is_library	boolean	no	Defaults to True: every reference is saved to the permanent signature library. False is still accepted (case-only reference). Either way, at this phase a reference is only compared against other documents in its own case — no cross-case/library-wide comparison logic runs yet.

SignatureReferenceResponse

One signature_references row returned by the API.

Field	Type	Required	Description
id	string (uuid)	yes	
person_name	string	yes	
signature_image_url	string (nullable)	yes	
bounding_box	object (nullable)	yes	
source_document_id	string (uuid)	yes	
source_case_id	string (uuid)	yes	
created_by	string (uuid)	yes	
is_library	boolean	yes	
created_at	string (date-time)	yes	

TokenResponse

Field	Type	Required	Description
access_token	string	yes	JWT. Send as <code>Authorization: Bearer <token></code> .
token_type	string	no	Always <code>bearer</code> .

UploadLimitsResponse

The calling company's upload limits, as enforced on its next upload.

Field	Type	Required	Description
max_file_size_mb	integer	yes	Largest document, in MB (1 MB = 1,048,576 bytes).
max_zip_size_mb	integer	yes	Largest bulk-upload zip, in MB.
max_file_size_bytes	integer	yes	
max_zip_size_bytes	integer	yes	

UsageResponse

Field	Type	Required	Description
period	string: "this_month", "last_month", "last_30_days", "this_year", "all_time", "custom"	yes	
start	string (date) (nullable)	yes	First UTC day included (null = from the beginning).
end	string (date) (nullable)	yes	Last UTC day included (null = up to today).
companies	array of CompanyUsageRow	yes	
totals	UsageTotals	yes	

UsageTotals

Field	Type	Required	Description
cases_created	integer	yes	
documents_uploaded	integer	yes	
files_stored	integer	yes	
storage_bytes	integer	yes	
total_storage_bytes	integer	yes	
total_files_stored	integer	yes	

UserAdminResponse

Field	Type	Required	Description
id	string (uuid)	yes	
email	string (email)	yes	
full_name	string (nullable)	yes	
role	UserRole	yes	
is_active	boolean	yes	
created_at	string (date-time)	yes	
company_id	string (uuid) (nullable)	yes	Null for platform admins.
company_name	string (nullable)	yes	

UserAdminUpdate

Field	Type	Required	Description
role	UserRole (nullable)	no	New role. Cannot be changed on your own account.
company_id	string (uuid) (nullable)	no	Move the user to another company (company roles only).
is_active	boolean (nullable)	no	False deactivates the account. Not allowed on yourself.

UserCreate

An account created by an administrator (there is no self-service sign-up). The password is set here and only ever stored hashed.

Field	Type	Required	Description
email	string (email)	yes	Login email. Unique regardless of letter case.
full_name	string (nullable)	no	Display name (optional).
role	UserRole	no	user , reviewer_l1 , reviewer_l2 or platform_admin .
company_id	string (uuid) (nullable)	no	Required for company roles; must be empty for platform_admin .
password	string	yes	Initial password (8-128 chars); stored hashed.

UserPasswordReset

Field	Type	Required	Description
password	string	yes	New password (8-128 chars); stored hashed.

UserRole

Allowed values: "user" , "reviewer_l1" , "reviewer_l2" , "platform_admin"

UserSummary

Field	Type	Required	Description
id	string (uuid)	yes	
email	string	yes	
full_name	string (nullable)	yes	

ValidationError

Field	Type	Required	Description
loc	array of string integer	yes	
msg	string	yes	
type	string	yes	